

웹기반 쇼핑몰 인프라 구축 및 취약점 진단

전체 인프라 이해 · 모의해킹 · 탐지 룰 연계 · 대응 점검

구분	내용
수행 기간	2026. 08. 03. ~ 2026. 08. 14. (12일)
작성자	최지우
담당 역할	웹 모의해킹 시나리오 수행 · 공격 시그니처 기반 탐지 룰 제공
점검 대상	VulnMart 쇼핑몰 웹 서버 및 DBMS
수행 환경	GNS3 기반 사설 네트워크 토폴로지 / VMware 기반 VM / 가상 계정·데이터

목차

장	내용	페이지
1	프로젝트 소개 · 전체 네트워크 · 전체 서버/서비스 구성	3 - 5
2	네트워크 구축 전반 · 라우팅 설계 · IP/VLAN · 접근 통제	6 - 7
3	서버·서비스 구축 전반 · 운영/백업 · OS·패키지 스택	8 - 10
4	모의해킹 · 검증 범위 · SCN-01~04 · 발견 취약점	11 - 19
5	탐지 룰 제공 · ALPACA 연계 · 룰셋 체계 · 대응 규칙	20 - 24
6	시나리오별 결과 · 결론 및 개인 기여	25 - 26
부록 A	쇼핑몰·웹하드·진단 구간 장비 명세	27
부록 B	관제·DNS·백업·관리 구간 장비 명세	28
부록 C	기술 리스트 (네트워크·서버·모의해킹·관제)	29 - 31

보고서의 구성 흐름



전체 인프라의 구축 규모를 이해한 뒤, 개인이 직접 수행한 모의해킹과 탐지 룰 제공 범위를 중심으로 정리했다. 취약점 후보·실제 공격 영향·탐지 결과·근본 조치는 각각 별도로 구분해 판정한다.

1. 프로젝트 소개 및 전체 구성

1-1. 프로젝트 목적과 수행 범위

전자상거래(쇼핑몰) 서비스를 직접 구성하고, 실제 공격자 관점에서 초기 침투 → 권한 획득 → 핵심 자산 접근으로 이어지는 공격 체인의 성립 가능성을 검증했다. 발견한 공격 특징은 탐지 룰로 정리해 관제 측에 제공했다.

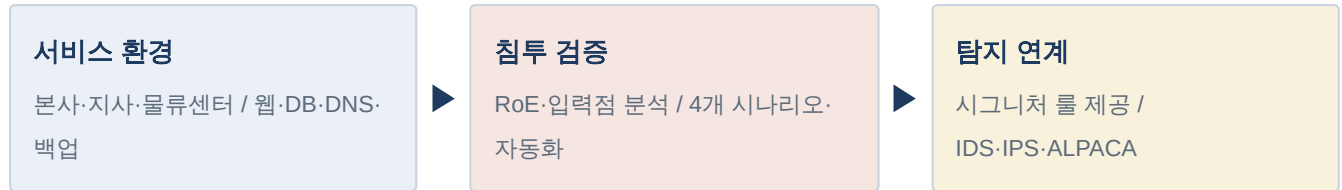


그림 1. 쇼핑몰 인프라 구축과 공격 시나리오 기반 통합 보안 솔루션 점검

구분	내용
전체 프로젝트	Cisco 이미지 기반 네트워크 · Linux·Windows 서버 취약점 쇼핑몰 · IDS/IPS·WAF · 중앙 분석·백업 및 주정통 점검 연계
보고서의 중심	웹 공격 표면과 취약점 분석, 네 가지 시나리오의 수행·자동화, 자산 영향 및 탐지 룰 제공
수행 환경	GNS3(Cisco c7200·c3745) · Rocky Linux·Ubuntu·Windows Server · Nginx·PHP·MariaDB · Kali Linux

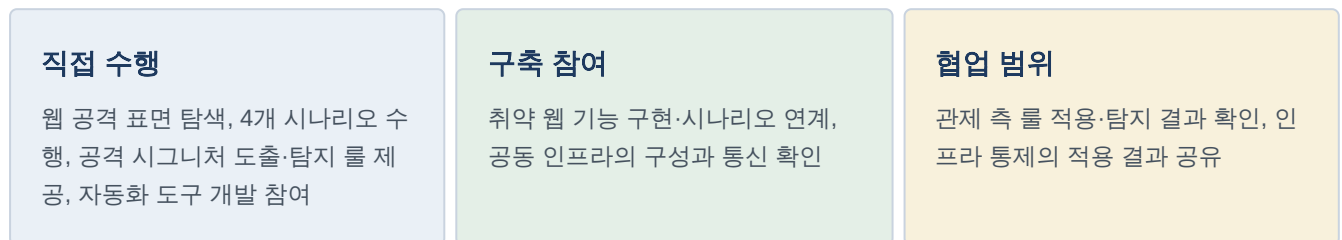


그림 2. 개인 직접 수행, 구축 참여, 협업 범위의 구분

1. 프로젝트 소개 및 전체 구성

1-2. 전체 네트워크 토폴로지

본사·지사·물류센터, 웹하드, 쇼핑몰 DMZ와 관제·관리 구간을 연결한 다중 영역의 실습 인프라를 구성했다.

2-1 . 네트워크 논리 토폴로지

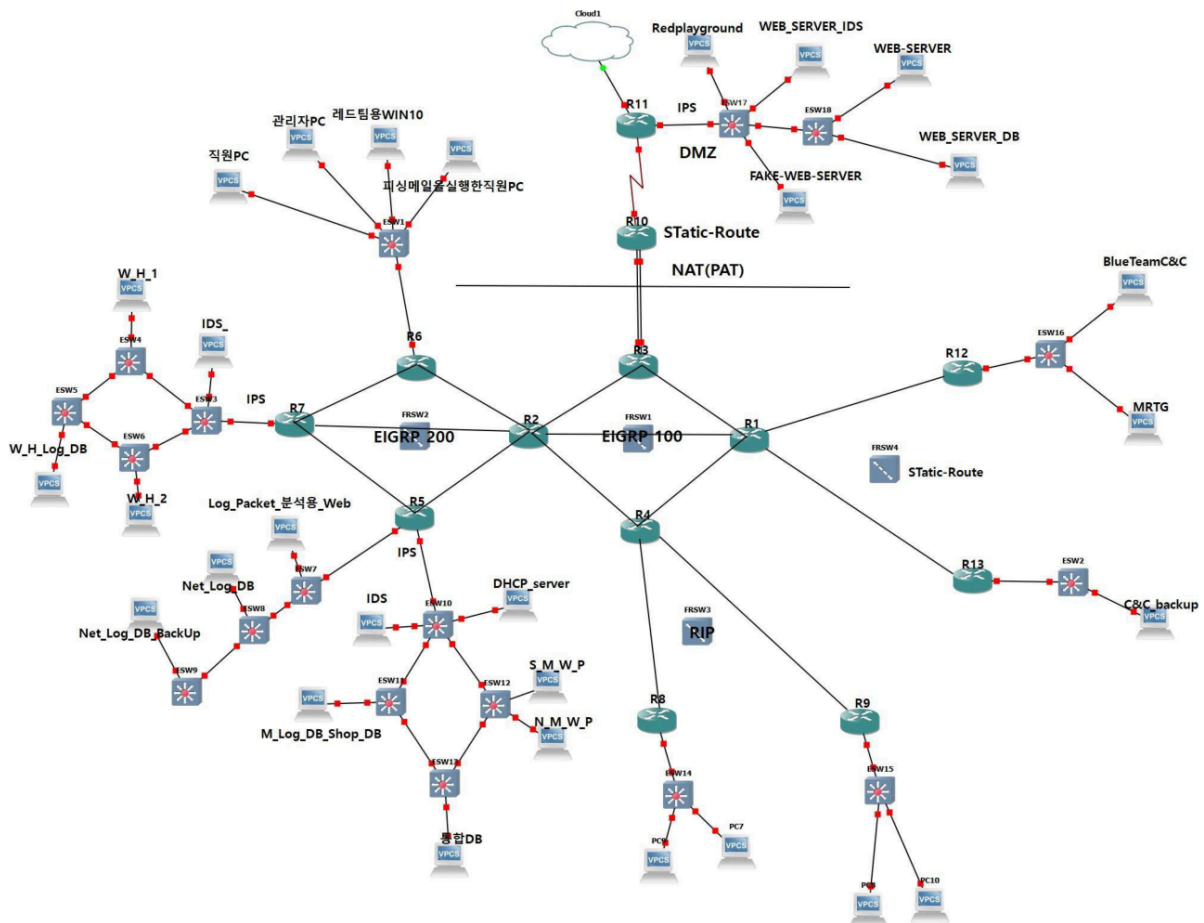


그림 3. 전체 논리 토폴로지: 코어·업무·외부 서비스·관제 구간

구간	주요 역할·연결
코어·분배	R1~R7 / EIGRP AS 100·200, 구간 간 경로 재분배
본사·지사	사용자망 및 R8·R9 물류·고객센터 / VLAN·RIPv2·DHCP
쇼핑몰 DMZ	R10·R11, ESW17·ESW18 / 외부 경계·웹·DB·진단·탐지
관제·관리	로그·백업·웹하드 및 R12·R13 관리 경로 / Static·SSH·접근 정책

1. 프로젝트 소개 및 전체 구성

1-3. 전체 서버와 서비스 구성

대외 쇼핑몰뿐 아니라 내부 파일 서비스, DNS·DHCP, 모니터링, 원격 관리와 백업을 함께 구성한 프로젝트다.

3-1. 서버 구성도

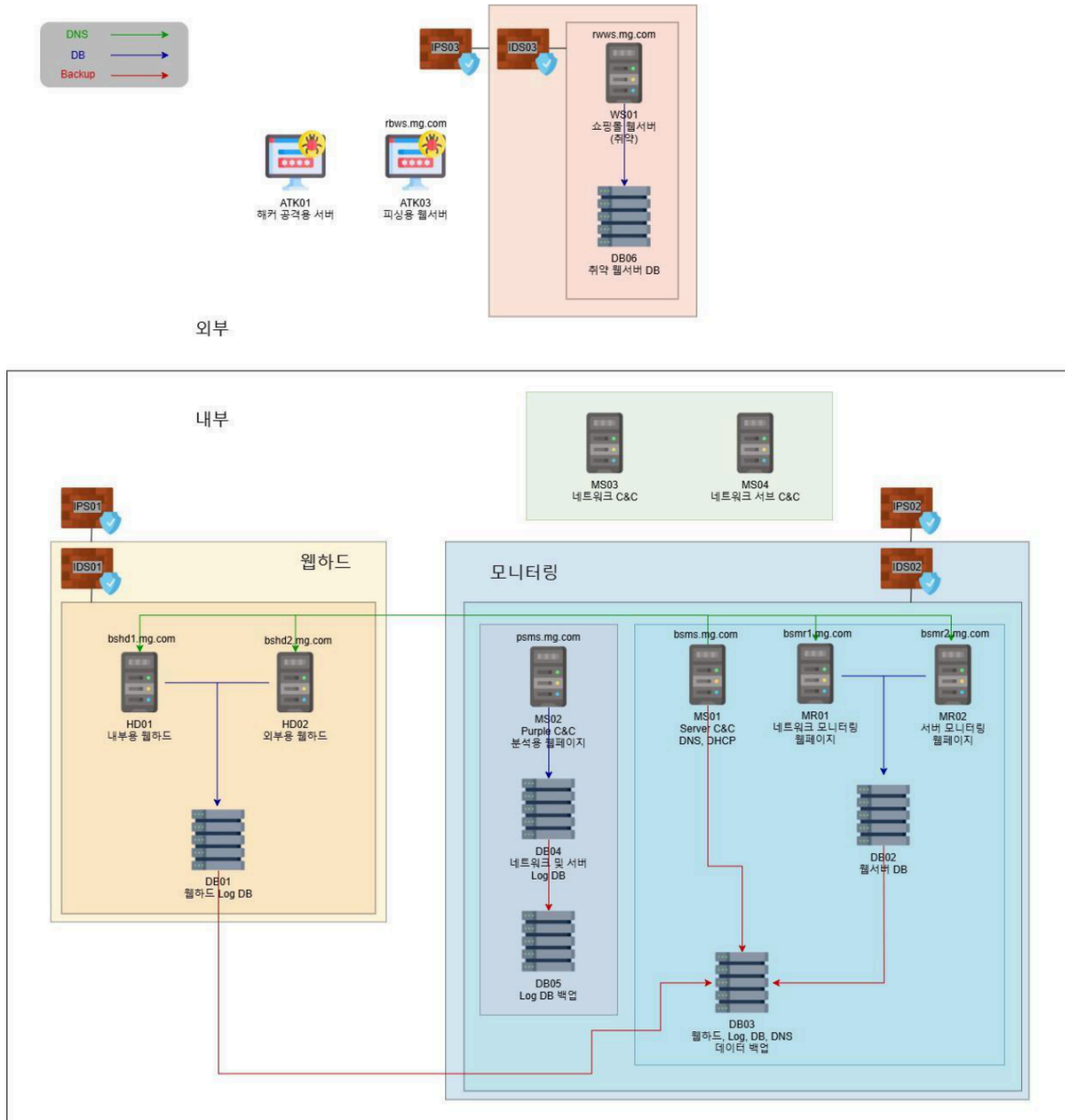


그림 4. 쇼핑몰·웹하드·모니터링·백업의 서버 배치 (외부/내부)

영역	연계 구성
대외 서비스	WS01·WS02-DB06 / 진단 단말 / IDS03·IPS03

2. 네트워크 구축 전반

2-1. 라우팅·구간 설계

쇼핑몰 서비스의 안정적 운영을 위해 구간을 역할별로 분리하고, 서로 다른 라우팅 영역을 재분배로 연동했다.

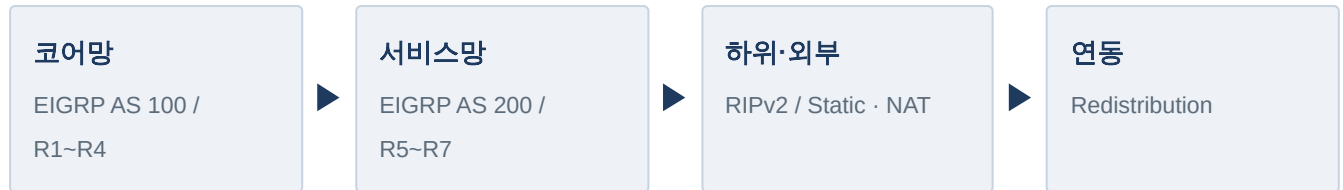


그림 5. 라우팅 영역 분리와 재분배 연동 구조

구간 / 프로토콜	주요 기술
코어망 (EIGRP 100)	Frame Relay P2P·Multipoint, Key-chain 인증, Static → EIGRP Redistribution, Distribute-list
서비스망 (EIGRP 200)	Manual Summary, Offset-list, Variance 부하분산, EIGRP Stub, Passive Interface
본사·지사 (RIPv2)	R8·R9 Gateway, RIPv2 ↔ EIGRP Redistribution, DHCP 주소 할당
외부·관리 (Static)	R10 NAT(PAT)·Floating Route, R11 DMZ 경계, R12·R13 관리 Static·SSH·ACL

구현 검증: 구간별 IP 대역·통신 경로, EIGRP Neighbor 및 Routing Table, Redistribution 간 Ping, NAT Translation, 관리망 한정 SSH 접근을 각각 확인했다. Key-chain의 AS 번호·인증 불일치 시 Neighbor 해제가 재현되어 라우팅 인증의 영향을 점검했다.

2. 네트워크 구축 전반

2-2. IP 대역 분배 · VLAN · 접근 통제

구간별 IP 대역을 역할에 따라 분배하고, VLAN·VTP·STP로 스위치 구간을, ACL·SSH로 관리 접근을 통제했다.

네트워크 구역	IP 대역 / Prefix	상세
코어망	10.10.0.0 /19	R1~R3 Multipoint / P2P, EIGRP 100 경계
코어·내부서버	10.30.0.0 /19	R2·R5·R6·R7 Multipoint, 서비스망 분배
내부 지사망	10.20.0.0 /19	R4·R8·R9 P2P, 물류·고객센터 LAN
외부망·DMZ	10.55.0.0 / 10.60.0.0	R10·R11, Web-Server·DB(10.60.0.10)
C&C 관리망	10.40.0.0 /19	R12·R13 Static, 관리 접근 전용
로그·모니터링	10.30.96~192.0	Log DB·웹 모니터링 VLAN (ESW7~ESW13)

스위치·접근 통제 요약

계층	적용 통제
스위치 (L2)	VLAN 분리, VTP Server/Client 배포, STP 루프 차단, Port-Security, SPAN(IDS 미러링)
라우터 (L3)	ACL 기반 구간 접근 제한, 관제용 SSH는 C&C 관리 영역에서만 허용
라우팅 인증	EIGRP·RIP 구간 Key-chain 기반 Routing Authentication

ACL은 공격 시그니처 탐지 수단이 아니라, 네트워크 구간 접근 범위를 제한하는 1차 통제 수단으로 사용했다. 서비스에 필요한 출발지·목적지·포트만 허용하는 화이트리스트 원칙을 적용한다.

3. 서버·서비스 구축 전반

3-1. 대외·내부 서버 역할

쇼핑몰(취약/보안), 웹하드, 모니터링, 관제·DNS·DHCP, 백업을 역할별 서버로 분리해 구축했다.

영역	서버	역할
대외(취약/보안)	WS01 / WS02	쇼핑몰 사이트 제공 (취약 / 보안 비교 사이트)
	DB06	쇼핑몰 회원·상품·주문 DB (MariaDB)
	ATK01 / ATK03	해커 공격용 서버(Kali) / 훈련용 피싱 웹페이지
내부 파일	HD01 / HD02	관리자용(Pydio·SMB) / 직원용(ownCloud·FTP) 웹하드
	DB01	웹하드 서비스 로그 저장 DB
모니터링·관제	MS01 / MS02	DNS Master·DHCP·도메인 / Purple C&C 분석 웹
	MR01 / MR02	네트워크(MRTG) / 서버(Cacti) 모니터링 웹
	DB02~DB05	모니터링·네트워크 Log DB 및 백업
보안 장비	IDS01~03 / IPS01~03	Snort3 탐지 / pfSense·Suricata 경계 통제

3. 서버·서비스 구축 전반

3-2. 서비스 운영 · 백업 · 보안

원격 관제와 실시간 모니터링, 자동 백업, 역할별 방화벽을 적용해 장애·보안 위협에 대응하도록 구성했다.

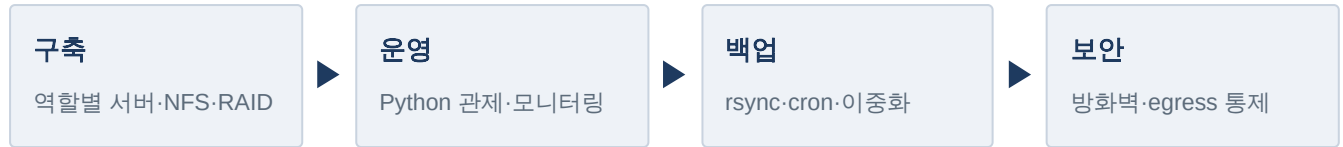


그림 6. 구축-운영-백업-보안의 서버 운영 흐름

항목	구축 내용
원격 관제	Python 기반 SSH 원격 서버 세팅·OS 초기화 자동화, GUI 분기 수행 (MS01 연동)
모니터링	MRTG·Cacti·Monitorix로 네트워크·서버 자원/트래픽 실시간 수집·시각화
저장·이중화	RAID 5 / 1+0 구성, Quota 용량 제한, NFS 마운트, DB03 통합 백업(평시 링크 Down)
자동 백업	rsync·scp·cron 기반 00:00~01:00 tar·zip 압축 후 백업, 90일 보관·자동 삭제
호스트 방화벽	iptables·firewalld·UFW 차등 적용, 인바운드 화이트리스트 + 아웃바운드 egress 통제

아웃바운드 영역에서 리버스 셸에 자주 쓰이는 4444·5555/tcp를 reject로 차단해, 침해 시 공격자 서버로의 역방향 연결과 내부 확산을 방지하도록 구성했다. (본 포트폴리오 4-7 SCN-03 대응과 직접 연결)

3. 서버·서비스 구축 전반

3-3. OS · 서비스 패키지 스택

구축에 사용한 운영체제와 핵심 서비스·패키지를 계층별로 요약한다. 상세 자산·버전은 부록 A·B에 수록한다.

계층	기술 · 패키지	주요 버전
운영체제	Rocky Linux 9.7 · Ubuntu 24.04 · Windows Server 2025 · FreeBSD(pfSense) · Kali	—
웹 서버	Nginx · Apache HTTP Server · IIS · Virtual Hosting	1.28.0 / 2.4.62 / 10.0
웹 애플리케이션	PHP · PHP-FPM · Python · Jupyter · Pydio Cells · ownCloud	8.4.23 / 3.9.25
DBMS	MariaDB · MySQL Client	10.5.29
DNS · IP	Microsoft DNS(Master) · BIND9(Slave) · DHCP IPv4	9.16.23
파일·전송	SMB(Samba) · FTP(vsftpd) · Rsync · SCP	4.19.5 / 3.0.5
모니터링	MRTG · Cacti · Monitorix (SNMP 기반)	2.17.7 / 1.2.26
보안	Snort3 · Suricata · pfSense · iptables · firewalld · UFW · TCP Wrapper	3.12.2 / 7.0.11 / 2.8.1
진단 도구	Nmap·Zenmap · Wireshark · Burp Suite · hydra · scapy · 커스텀 PHP·Python	—

취약 쇼핑몰(WS01)은 Nginx 1.28.0 · PHP 8.4.23 · MariaDB 구성이며, 주 진단 대상(10.60.0.10)은 nginx 1.20.1 · PHP 8.0.30 · MariaDB 기반의 GNS3 격리 훈련망으로 운용했다.

4. 모의해킹 (직접 수행)

4-1. 검증 범위와 RoE

전체 인프라 중 쇼핑몰 서비스 구간을 직접 검증 대상으로 선정했다. 운영 고객정보나 합의 밖 자산으로 범위를 확대하지 않았다.



그림 7. 쇼핑몰 서비스 구간(DMZ)의 검증 범위

합의 항목	수행 기준
대상	VulnMart 웹·연계 DB, 승인된 진단 및 훈련용 피싱 거점. 주 시나리오 주소 10.60.0.10
계정·데이터	교육용 계정(admin/alice/bob/victim)과 가상 주문·결제 데이터 사용. 실제 고객·실결제 제외
허용·제외	합의된 웹 입력점 검증과 시나리오 수행. 합의 외 스캔·공격, DoS, 데이터 파괴·실고객 변조 금지
선행 조건	기본 블랙박스, 저장형 XSS·업로드 일부 단계는 승인된 조건을 부여한 그레이박스 병행
성공 기준	정상 요청과 다른 권한·데이터·실행 결과를 증적으로 확인. 오류·경보만으로 성공을 확정하지 않음

수행 방식: MITRE ATT&CK 전술·기법과 사이버 킬체인 절차를 참고해 정찰→취약점 분석→침투→후속 공격→보고의 7단계로 수행했다.

4. 모의해킹 (직접 수행)

4-2. 취약 사이트 기능과 입력점

Nginx·PHP-FPM·MariaDB 기반 쇼핑몰의 정상 기능 안에 취약한 처리 지점을 구성하고, 해당 업무가 자산 영향으로 이어지는지 검증했다.

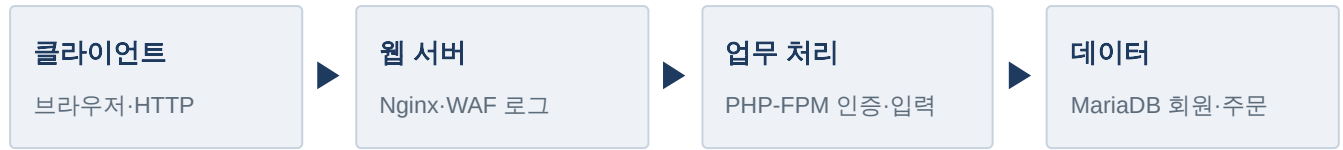


그림 8. HTTP 요청·PHP 업무 처리·DB·파일 접근의 신뢰 경계

업무 기능	입력·처리 관계	진단 연결
로그인 (login.php)	username·password → 인증·세션	SQLi · 반복 인증
검색 (search.php)	q → DB 조회 → HTML 응답	SQLi · 오류 노출·반사 후보
후기·게시글 (post_new.php)	본문 저장 → 타 사용자 화면에 출력	저장형 XSS · 피싱
프로필 (profile.php)	파일 수신 → 저장 → 웹 경로 접근	업로드 · 서버 실행
주문·결제 (orders.php)	주문 ID·세션 → 조회·상태 변경	권한 · CSRF · 업무 무결성

정찰 단계에서 로그인 페이지에 교육용 계정·비밀번호가 평문 노출되어 있음을 확인했고, 사이트 내부 링크·폼 action·method·입력 필드를 수집해 인증 전후 경로를 비교했다.

4. 모의해킹 (직접 수행)

4-3. 취약점 탐색과 OWASP-CWE 분류

스캐너의 신호는 검증 대상 선정에 사용하고, 실제 실행 문맥과 자산 영향이 확인된 항목을 별도로 판정했다.

108 저장 URL 쿼리 변형 포함	27 고유 경로 path 기준 중복 제거	19 검토 레코드 확정 취약점 수 아님
---	--	---

그림 9. 엔드포인트 탐색 저장 결과의 범위

항목	CWE / OWASP 2021	시나리오·검증 성격
V-01-02 로그인·검색 SQLi	89 / A03	SCN-01: 인증 우회·스키마·회원 조회
V-03 저장형 XSS	79 / A03	SCN-02 중심: 콘텐츠 삽입·피싱 연계
V-04 쿠키 보안속성	1004·614 / A05	SCN-01-02의 세션 보호 보조 항목
V-05-06 HTTP·결제정보 평문	319·311 / A02	SCN-02 관찰 구간·정보 노출 조건
V-07 오픈 리다이렉트	601 / A01	SCN-02 피싱 유도 연계; 독립 검증
V-08-09 업로드 검증·RCE	434·94 / A05·A03	SCN-03: 업로드 수용과 서버 실행
V-10 반복 인증 방어 미흡	307 / A07	SCN-04: 반복 시도 이후 로그인 확인
V-11 평문·약한 인증정보	256·312 / A02	SCN-01-04를 쉽게 만드는 환경 조건
V-12~14 오류 노출·CSP·WAF 모드	209 / A05 등	탐색 단서·독립 공격 성과와 분리 관리

4. 모의해킹 (직접 수행)

4-4. 네 시나리오의 구성과 성공 기준

공통 탐색 결과에서 네 경로로 분기하고, 각 경로 안에서 선행 조건·행위·자산 영향을 연결했다.

SCN-01	인증 입력 로그인 SQLi	권한 경계 관리자 세션	데이터 조회 회원정보 노출
SCN-02	저장 콘텐츠 후기/게시글	신뢰 악용 쿠폰·외부 이동	업무 영향 더미 결제정보
SCN-03	파일 입력 프로필 업로드	서버 해석 PHP 실행 경로	호스트 영향 셸 연결
SCN-04	인증 응답 정상/실패 구분	반복 요청 고정 후보 대입	계정 영향 로그인 상태 확인

그림 10. 네 시나리오의 진입점과 도달 자산

시나리오	성공 판단에 필요한 증거
SCN-01	인증 우회 후 권한 확인, 검색 응답의 스키마·회원 데이터
SCN-02	저장된 콘텐츠 재출력, 외부 피싱 이동, 가상 결제 흐름
SCN-03	업로드 수용, 파일 접근·서버 실행, 실제 셸 연결
SCN-04	반복 요청의 실패·성공 차이와 최종 로그인 상태

자동화 도구 개발 참여

동일한 입력·요청을 반복 수행할 수 있도록 공통 통신 기반과 시나리오 실행부를 분리해 구현했고, 아래 자체 개발 도구의 개발에 참여했다.

자체 개발 도구	역할
PCrafter	Ethernet·IP·TCP·HTTP 계층별 패킷 빌더와 RawTcpSession·RawHttpSession 세션 처리 기반
real_main.py	엔드포인트(URL·폼·입력점) 탐색·수집 — 108 URL·검토 레코드 저장
Vulnmart_ATTACK.py	로그인 SQLi·저장형 XSS·업로드·반복 로그인 요청을 자동화한 시나리오 공격 스크립트

4. 모의해킹 (직접 수행)

4-5. SCN-01 | 인증 우회와 회원정보 접근

로그인 입력이 인증 조건을 바꾸는지 검증한 뒤, 검색 기능을 통해 DB 구조와 회원정보 노출로 영향이 확대되는 경로를 단계별로 수행했다.

1

로그인 인증 우회

login.php username에 Boolean 기반 SQLi(' OR '1'='1' --)를 입력해 인증을 우회



그림 11-1. 로그인 입력 SQLi

2

관리자 세션 획득

인증 우회 후 관리자 세션 (vm_role=admin)이 발급되고 /admin/ 접근이 되는지 확인

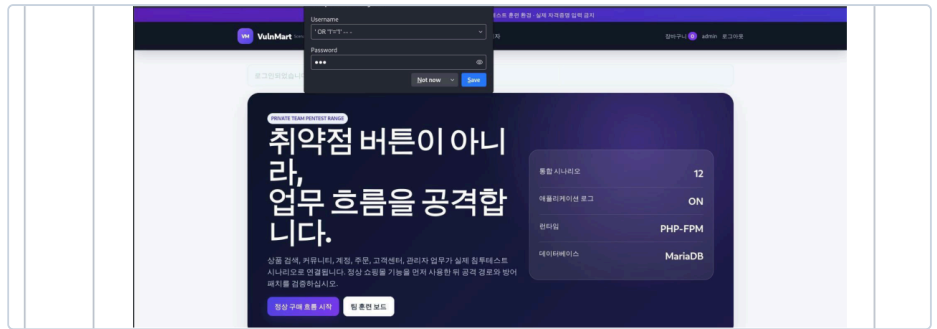


그림 11-2. 인증 우회 후 관리자 화면 표시

3

스키마·회원 조회

search.php q에 UNION 기반 SQLi로 users 테이블·컬럼을 열거하고 회원 자격증명을 덤프 — admin·alice·bob·victim 식별

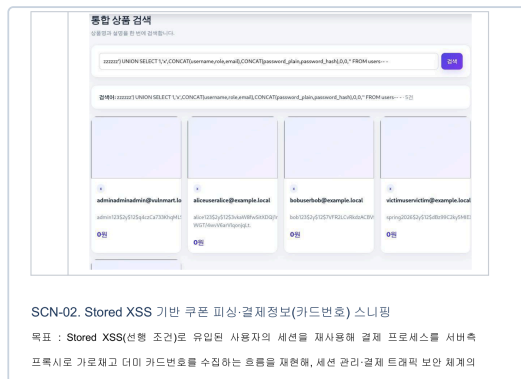


그림 11-3. UNION 검색으로 식별한 회원 계정

CWE-89 / A03:2021 · SQLi 세션 발급은 인증 우회다. 가시 영역에서 4개 계정을 식별했으며, 이는 해당 요청의 관측 범위이고 전체 회원 수나 실제 고객 피해 규모는 아니다.

4. 모의해킹 (직접 수행)

4-6. SCN-02 | 저장형 XSS와 쿠폰 피싱

쇼핑몰의 후기·게시글 신뢰를 이용해 쿠폰 콘텐츠를 표시하고, 별도 훈련용 피싱·결제 흐름으로 사용자를 유도하는 과정을 단계별로 수행했다. (저장형 XSS 성립·세션은 승인된 선행 조건, 실고객·실카드 제외)

1

저장형 XSS 삽입

취약 후기·게시판에 외부 피싱으로 연결되는 "쿠폰 받기" 버튼을 저장형 XSS로 삽입, 다른 조회 화면에서의 재출력을 확인

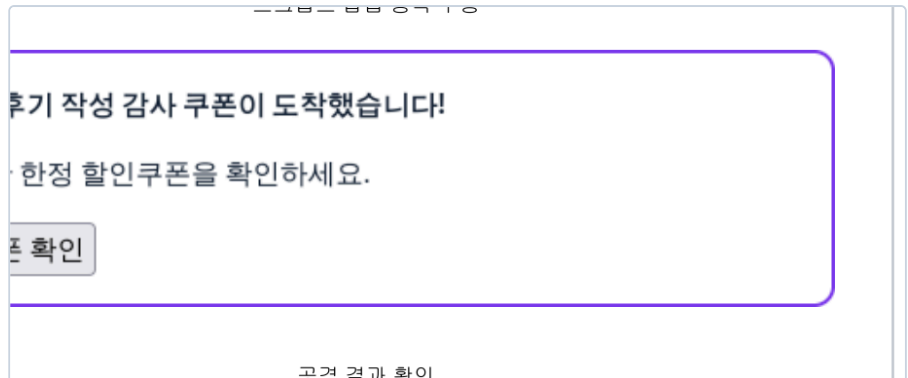


그림 12-1. 후기 영역에 재출력된 쿠폰 유도 콘텐츠

2

피싱 거점 이동·입력

버튼 클릭 시 훈련용 피싱 거점으로 이동, 쿠폰 적용을 위해 배송지·카드번호 입력을 유도. 결제(POST /checkout)는 scapy로 선별 스니핑

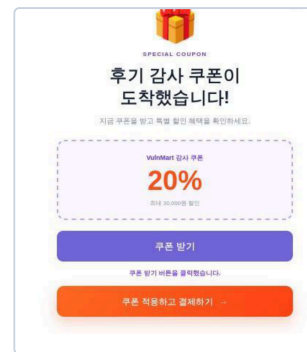


그림 12-2. 외부 피싱 거점의 쿠폰 화면

3

결제 완료·복귀

가상 결제 흐름 후 실제 쇼핑몰로 리다이렉션. 외부 수집 건수·피해 규모는 대상 로그에 남지 않아 별도 증거로 구분

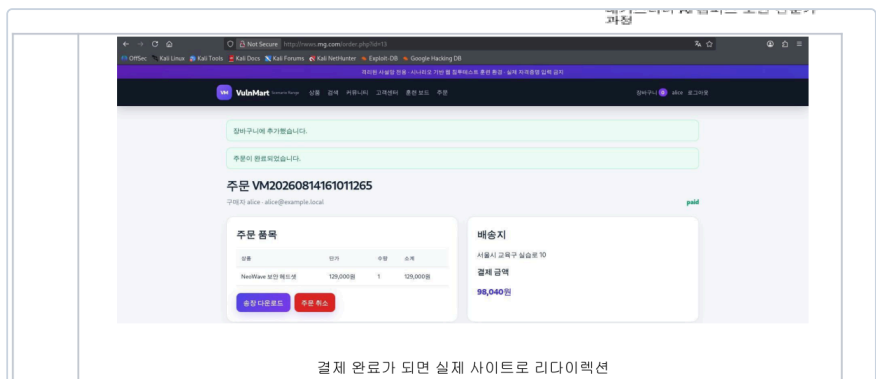


그림 12-3. 결제 흐름 후 쇼핑몰 주문 화면

CWE-79·319 / A03·A02:2021 · HTML 콘텐츠 표시, 스크립트 실행, 쿠키 수신, 카드정보 수집은 서로 다른 증거다. 쿠폰 화면만으로 전 단계를 완료 처리하지 않았다.

4. 모의해킹 (직접 수행)

4-7. SCN-03 | 업로드에서 서버 실행까지 (RCE)

프로필 이미지 기능이 위험 확장자를 수용하고 해당 파일을 웹 실행 경로에서 처리할 때, 파일 업로드가 서버 제어로 확대되는지 단계별로 확인했다. (업로드 권한·실행 조건은 그레이박스 범위)

1

.php 업로드

마이페이지 프로필 사진 업로드란에 허용 이미지가 아닌 실행 파일(.php) 업로드가 가능한지 확인하고, bash 리버스 셸 코드를 담은 .php를 업로드

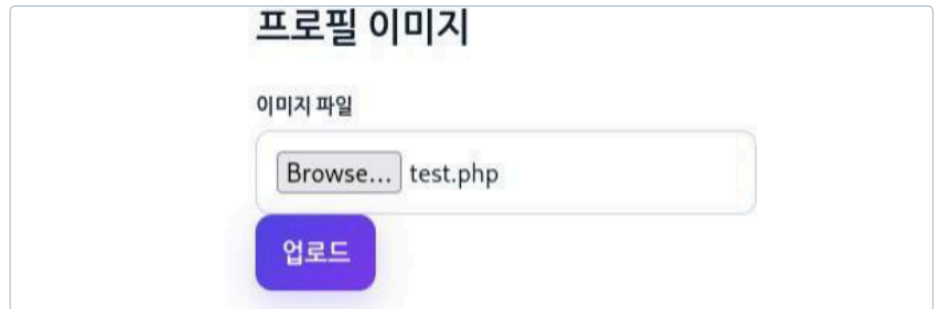


그림 13-1. PHP 파일을 선택한 프로필 업로드

2

서버 실행·리버스 셸

공격자 PC에 nc 리스너(4444) 대기 후, 업로드 파일을 프로필로 적용하는 과정에서 서버가 파일을 실행 → 웹 서버에서 시작된 연결·셸 프롬프트 관측

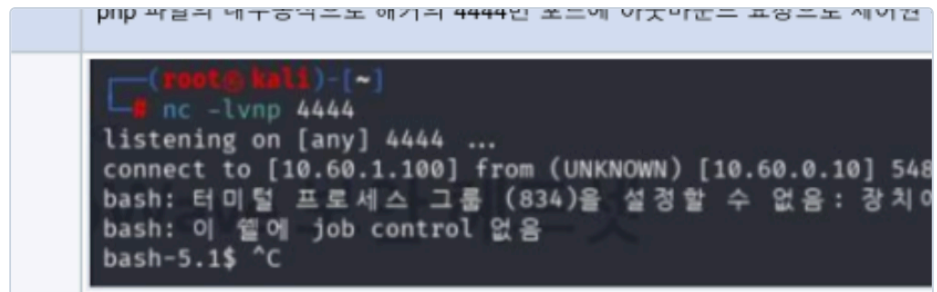


그림 13-2. 업로드 파일 실행으로 성립한 리버스 셸 연결

CWE-434·94 / A05·A03:2021 · 파일 선택은 증거의 일부이며, 서버 실행 여부는 연결·프로세스·응답과 함께 판정한다. 영향 범위는 대상 WAS 1대의 실행 경계이며, root 승격·다른 서버 전파·전체 파일 반출은 미입증이다.

4. 모의해킹 (직접 수행)

4-8. SCN-04 | 반복 인증과 발견 취약점 종합

실패·성공 응답 차이를 먼저 확인한 뒤 고정 후보군으로 반복 인증을 수행했다.

1

후보군 준비

아이디·패스워드 리스트

(users.txt·passwd.txt)와 무차별 대입

도구(hydra) 준비

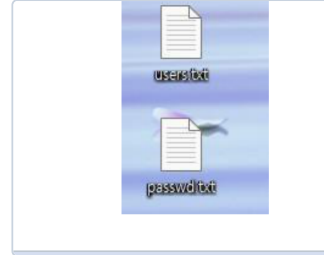


그림 14-1. 무차별 대입용 wordlist

2

응답 패턴 분석

로그인 시도 패킷에서 실패=HTTP

200, 성공=HTTP 302 차이를 확인 —

302가 유효 계정의 유일한 신호

```
71 HTTP/1.1 200 OK (text/html)
655 POST /login.php HTTP/1.1
675 HTTP/1.1 302 Found [Last
500 GET / HTTP/1.1
```

그림 14-2. 로그인 실패 200 · 성공 302

3

hydra 반복 대입·탈취

S=302 조건으로 자동 대입하여 유효

계정(admin·alice) 매칭, 획득 자격증명

으로 로그인해 계정 탈취

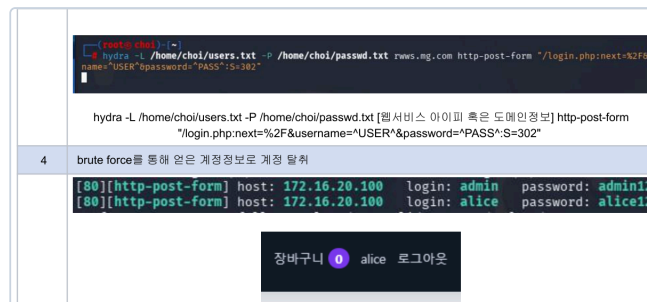


그림 14-3. hydra 매칭(admin·alice)

CWE-307 / A07:2021 · HTTP 302만으로 일반화하지 않고 로그인 세션과 후속 접근을 확인했다.

4. 모의해킹 (직접 수행)

4-9. 발견 취약점 종합 (V-01 ~ V-14)

네 시나리오에서 확인·검토한 취약점을 OWASP·CWE와 위험등급으로 종합한다. 긴급 2주·높음 1개월·중간 2개월 내 조치를 목표로 우선순위를 부여했다.

취약점	위험등급	시나리오
V-01·02 로그인·검색 SQL Injection	긴급	SCN-01
V-08·09 업로드 검증 미흡·서버 실행(RCE)	긴급	SCN-03
V-03 저장형 XSS	높음	SCN-01/02
V-04 세션 쿠키 보안속성 미설정	높음	SCN-01/02
V-06 결제 트래픽 카드번호 평문	높음	SCN-02
V-10 로그인 무차별 대입 방어 미흡	높음	SCN-04
V-11 평문·약한 비밀번호(교육용 평문 노출)	높음	SCN-01/04
V-05 평문 HTTP 전송 / V-07 오픈 리다이렉트	높음 / 중간	SCN-02
V-12 상세 오류 노출 / V-13 CSP 미도입 / V-14 WAF DetectionOnly	중간 / 낮음	전체

분류 기준: CWE / OWASP Top 10:2021. 위험등급은 핵심 자산(인증·회원 DB·서버 실행)에 직접 연결되는 경로에 높게 부여했으며, 환경 노출·보조 보안속성·운영 설정 항목은 독립 공격 성과와 분리해 관리한다.

5. 탐지 룰 제공 및 룰셋

5-1. 공격 특징의 룰 연계와 ALPACA

각 시나리오의 공격 특징을 탐지 시그니처로 정리해 관제 측에 제공했다. 제공한 룰은 ALPACA 통합 분석 환경에서 패킷·로그와 함께 상관 분석된다.

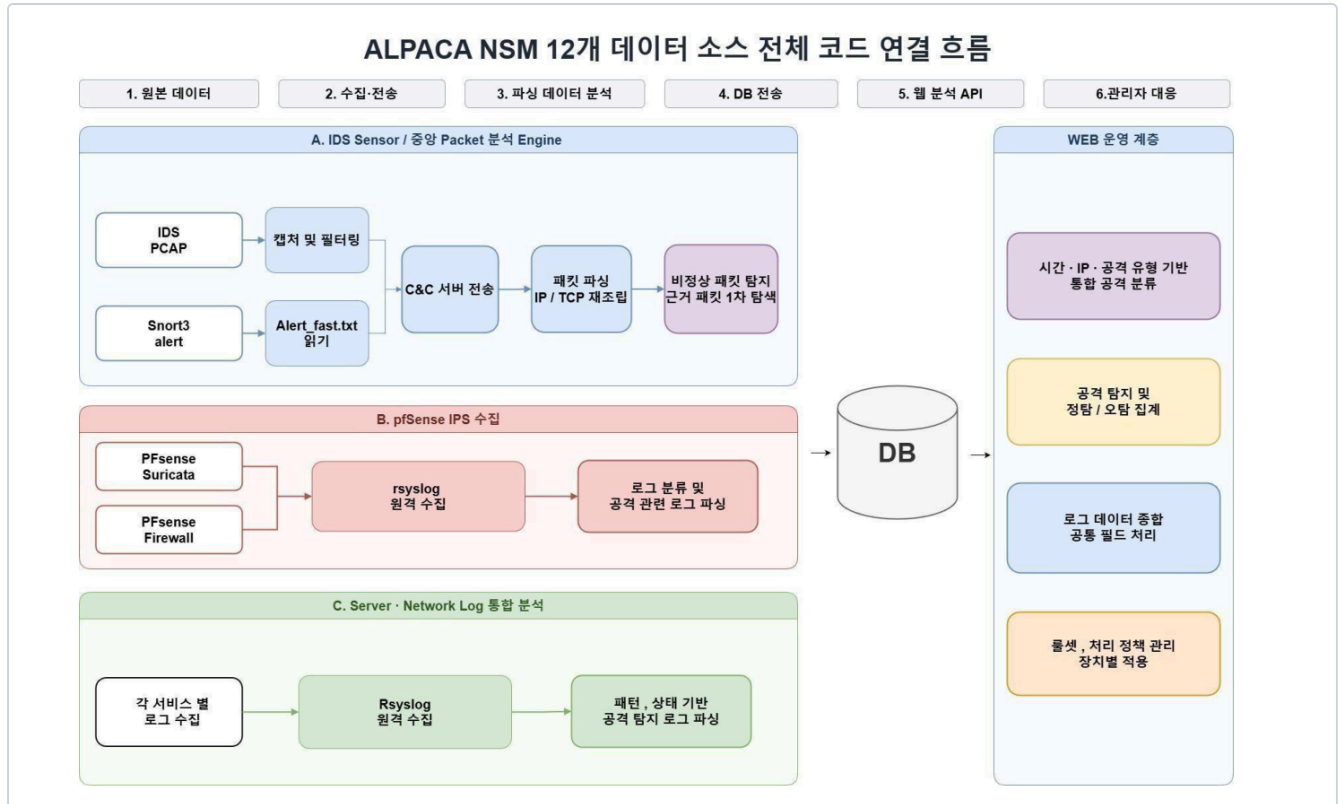


그림 13. 센서·방화벽·서버 로그가 DB와 ALPACA 조사 화면으로 연결되는 구조

공격 재현 기여: 공격 재현 시 발생하는 요청·페이로드 특징(SQLi 주석/항진식, UNION+인증 컬럼, document.cookie, 위험 확장자 업로드, 반복 로그인 등)을 정리해 SID 설계의 입력으로 제공했다. 룰 구현·배포와 ALPACA 분석은 관제 측 협업 결과로 구분한다.

5. 탐지 룰 제공 및 룰셋

5-2. 룰셋 분류 체계와 분배

제공한 공격 특징은 SID 범위로 분류하고, IDS는 Alert 중심, IPS는 확정 시그니처 Drop 중심으로 분배하도록 정리했다.

SID 범위	분류	설명
1XXXXXX	기본 프로토콜	ICMP, DNS, FTP, SSH, SMB, DHCP 등
2XXXXXX	웹 공격	SQL Injection, XSS, CSRF, File Upload
3XXXXXX	네트워크 공격	Brute Force, MITM, Session Hijacking, Reverse Shell
4XXXXXX	스캐닝·정찰	Nmap, Zenmap, Scapy, Port Scan
5XXXXXX	시스템 공격	Shell command, 중요 파일 접근
6XXXXXX	테스트	룰 테스트·실험용

룰셋 분배 정책

위치	정책 · 예시
IPS Drop	공격 의도가 명확하고 오탐 가능성이 낮은 이벤트. 예) RLO 문자열, SQLi union select + password
IPS Alert	차단 후보 관찰 이벤트. 예) 파일 위험 확장자 탐지
IDS Alert	추가 분석이 필요한 행위. 예) Nmap scan, Login Fail

IDS는 트래픽을 직접 차단하지 못하므로 Alert로 분석 이벤트를 선별한다. 구간별 정상 트래픽 성격에 따라 Drop 적용 폭을 차등 적용했다(웹하드는 확정 시그니처만 Drop, 모니터링은 폭넓게).

5. 탐지 룰 제공 및 룰셋

5-3. 시나리오별 탐지 룰 (IDS03 / IPS03)

수행한 네 시나리오의 공격 단계를 SID로 매핑해 제공했다. 웹 공격 구간(RedZone)의 핵심 룰은 다음과 같다.

SID	메시지	탐지 시그니처
2001006	SQL Injection - SQL Comment on Login	로그인 주석 -- # /*
2001010	SQL Injection - Always True Condition	항진식 ' OR '1'='1'
2001009	SQL Injection - Information Schema Column	테이블 구조 조회
2001008	UNION SELECT Credential Fields	Password 컬럼 조회
2003005	Stored XSS cookie	document.cookie
2006002	FILE UPLOAD - Extension/Content-Type Mismatch	.php·js·sh 등 확장자
5002001	WEB SHELL - Interactive Shell Command	pwd·id·whoami·uname
5001001 / 5001003	WEB SHELL / Bash Shell - Outbound·External	서버 외부 SYN, nc·dev/tcp
3001001	BF - Login Attempt	60초 내 로그인 10회 이상
4001001 / 4007003	TCP SYN Scan / SSH Banner Disclosure	정찰·스캐닝(Zenmap)

IPS03(pfSense+Suricata)는 위 룰 중 확정 시그니처(SQLi 주석, UNION+Password, RLO, 위험 확장자, Reverse Shell Outbound)를 Drop으로 전환해 외부 유입 웹 공격을 1차 차단하도록 제공했다.

5. 탐지 룰 제공 및 룰셋

5-4. 조치 권고에서 대응 규칙으로의 전환

권고안을 그대로 문자열 규칙으로 옮기지 않고, 실제 관측 가능한 요청 특징과 적용 계층·동작·검증 조건으로 분해해 제공했다.



그림 14. 반복 로그인 사례: 관측 특징이 SID와 운영 조치로 연결되는 과정

시나리오	대응 규칙 요지
SCN-01 SQLi	로그인·검색 입력을 SQL 문법과 분리(준비문·바인딩), 인증정보 검증·DB 권한 점검. 주석/항진식·Information Schema·UNION 탐지 룰 제공
SCN-02 XSS·피싱	출력 컨텍스트 인코딩/Sanitizer·CSP. <script>+document.cookie 결합 시 세션 탈취로 판단, 비정상 쿠폰·결제 신고 경로
SCN-03 업로드·RCE	확장자·MIME·매직바이트 화이트리스트, 웹루트 외 저장·실행권한 제거. 위험 확장자 3회 이상 시 업로드 임시 DROP
SCN-04 반복 인증	요청 속도 제한·계정 잠금·MFA. SID 3001001 Alert 후 관리자 판단으로 pfSense 임시 차단

본인은 HTTP·PCAP·시각·대상과 예상 탐지 포인트를 전달했다. SID 등록, 이벤트 발생, 차단 적용, 정상 회귀는 모두 같은 완료 상태가 아니며 이행점검으로 구분해 관리한다.

5. 탐지 룰 제공 및 룰셋

5-5. 제공 룰의 탐지 이벤트 확인

제공한 룰이 실제 공격 트래픽에서 발생하는지, ALPACA 로그 상관 분석과 Python 판정 기준으로 함께 확인했다.

시나리오	확인된 탐지 이벤트 (요약)
SCN-01 SQLi	SQL Comment on Login, Always True Condition, Information Schema Column, UNION SELECT Credential Fields — modsecurity(942100)·MariaDB audit 상관
SCN-02 XSS·피싱	Stored XSS cookie(2003005), 세션 하이재킹(동일 쿠키 IP 변경) — nginx access·WAF 상관
SCN-03 업로드·RCE	Filename/Content-Type Mismatch, Bash Shell Command/External, WEB SHELL Outbound — auditd EXECVE·php-fpm 상관
SCN-04 반복 인증	Login Failed ×44 / BF-Login Attempt(3001001), 성공 302 ×3 — access·audit 상관

Python 분석 판정 기준 (예시)

attack_type	판정 기준	상태
SQLI_AUTH_BYPASS_SUCCESS	Login SQLi 요청 뒤 성공 응답·세션 쿠키 발급	CONFIRMED
STORED_XSS_CONFIRMED	입력 특징이 같은 서버의 다른 Flow 응답에서 반환	CONFIRMED
SUSPECT_SERVER_OUTBOUND	위험 업로드 이후 서버가 비허용 외부로 연결	핸드셰이크 완료 시 CONFIRMED
HTTP_LOGIN_BRUTE_FORCE	60초 내 Login 실패 응답 10회	CONFIRMED

6. 결론 및 성과

6-1. 시나리오별 결과와 조치

공격 영향과 탐지, 기반 통제 적용은 확인했으나, 모든 시나리오의 근본 취약점이 제거된 상태는 아니다.

시나리오	공격 영향	탐지	근본 조치·재발방지
SCN-01 SQLi	인증·회원 조회 확인	확인	준비문 전환 이행점검 필요
SCN-02 XSS·피싱	콘텐츠·피싱 흐름 확인	관련 이벤트 확인	인코딩·CSP 이행점검 필요
SCN-03 업로드	서버 셀 연결 확인	관련 이벤트 확인	연결 실패 기록만으로 완료 불가
SCN-04 반복 인증	로그인 상태 확인	확인	제한·잠금 후 정상 회귀 필요

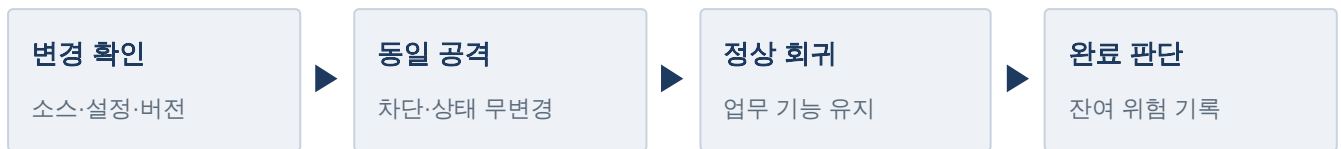


그림 15. 탐지·차단·근본 조치의 완료 단계를 분리한 관리

방어 완료는 동일 공격의 차단과 정상 업무 유지가 함께 확인된 상태로 정의했으며, 긴급·높음 항목부터 이행 계획과 재점검 결과를 관리한다.

6. 결론 및 성과

6-2. 결론 및 개인 기여

다중 구간 인프라와 중앙 관제 환경 안에서 쇼핑몰의 검증 범위를 정하고, 취약점 탐색·시나리오·자산 영향·탐지 룰 제공을 연결했다.

분석

기능·입력점에서 출발해 검증할 가설을 좁히고 OWASP·CWE로 분류했다.

침투

인증 우회·회원 조회·피싱 유도·서버 실행·반복 인증의 영향을 분리해 수행했다.

대응

관측 특징을 탐지 룰로 연결해 관제 측에 제공하고 완료 기준을 나눴다.

구분	핵심 기여
모의해킹 수행	웹 공격 표면 탐색(108 URL·27 경로), SCN-01~04 수행·증적화, MITRE ATT&CK 기반 공격 체인 구성
탐지 룰 제공	SQLi·XSS·업로드·브루트포스의 관측 특징을 SID 설계 입력으로 제공, IDS Alert / IPS Drop 분배 권고
자동화 도구 개발 참여	자체 개발 도구(PCrafter · real_main.py · Vulnmart_ATTACK.py) 개발 참여
구축 참여	취약 웹 기능 구현·시나리오 연계, 공동 네트워크·서버 인프라 구성·통신 확인

최종 판단: 네 가지 시나리오의 수행·탐지 및 일부 인프라 통제를 확인했다. 근본적 재발 방지 조치는 완료되지 않았으며, 이는 위협 탐지 가능 여부에 중점을 두고 진단을 진행했기 때문이다. 범위를 벗어난 자산과 실제 운영 피해 규모는 추가 진단 대상으로 남긴다.

A-1. 쇼핑몰·웹하드·진단 구간

서비스 역할과 소프트웨어·주요 설정을 요약한다. 사실 실습 도메인이며, 구축 범위와 각 항목의 보안 완료 여부는 구분한다.

자산	역할 / OS	서비스·주요 버전	도메인·설정·연계
WS01	취약 쇼핑몰 / Rocky 9.7	Nginx 1.28.0 · PHP 8.4.23 / PHP-FPM	rwws.mg.com · HTTP 80 / DB06 TCP 3306
WS02	보안 비교 사이트 / Rocky 9.7	Nginx 1.28.0 · PHP 8.4.23	bsws.mg.com · 관리 SSH 출 발지 제한
DB06	쇼핑몰 DB / Rocky 9.7	MariaDB 10.5.29	회원·상품·주문 저장 · WAS → TCP 3306
ATK01	진단 단말 / Kali Linux	Nmap·Wireshark·Hydra·scapy·Python	승인된 대상 요청·증적 수집
ATK03	훈련용 피싱 웹 / Rocky 9.7	Nginx 1.28.0 · PHP 8.4.22	rbws.mg.com · 가상 쿠폰·결 제 흐름
IDS03	쇼핑몰 패킷 탐지 / Rocky 9.7	Snort 3.12.2	웹 공격·정찰 · ESW17 미러 링 관찰
IPS03	쇼핑몰 경계 통제 / FreeBSD	pfSense 2.8.1 · Suricata 7.0.11	브리지 / Alert·Drop 분배
HD01	관리자 웹하드 / Ubuntu 24.04	Nginx 1.24.0 · Pydio 5.0.2 · SMB 4.19.5	bshd1.mg.com · DB01 연계
HD02	직원 웹하드 / Rocky 9.7	Apache 2.4.62 · ownCloud 10.16.0 · FTP	bshd2.mg.com · 관리 SSH· 외부 연결 통제
DB01	웹하드 로그 DB / Ubuntu 24.04	MariaDB 10.5.29	TCP 3306 / 반복 연결 60초 5 회 기준 시험
IDS01 / IPS01	웹하드 관찰·통제 / Rocky·FreeBSD	Snort 3.12.2 · pfSense 2.8.1	FTP·SMB·파일 반입 · 확정 특징 Drop

B-1. 관제·DNS·백업·관리 구간

중앙 분석과 지원 서비스가 쇼핑몰 진단 증적을 받는 구조를 요약한다. ALPACA·수집 엔진·지원 서버는 공동 프로젝트 구성이다.

자산	역할 / OS	서비스·주요 버전	핵심 설정·운영 상태
MS01	서버 관리·DNS·DHCP / Windows Server 2025	IIS 10.0 · Microsoft DNS · Python·Jupyter	bsms.mg.com · Master DNS·DHCP IPv4
MR01	네트워크 모니터링 / Rocky 9.7	Apache 2.4.62 · MRTG 2.17.7	bsmr1.mg.com · SNMP 기반 수집
MR02	서버 모니터링 / Ubuntu 24.04	Nginx 1.24.0 · Cacti 1.2.26	bsmr2.mg.com · 서비스-DB 연동
DB02	모니터링 로그 DB / Ubuntu 24.04	MariaDB 10.5.29	MR01·MR02 로그 저장 대상
DB03	통합 백업·DNS Slave / Ubuntu 24.04	MariaDB 10.5.29 · BIND9 9.16.23	DB01·DB02·MS01 백업 / 평시 링크 제한
DB04 / DB05	네트워크 로그 DB·백업 / Rocky 9.7	MariaDB 10.5.29	psdb1·psdb2.mg.com · 중앙 로그 저장·백업
MS02	중앙 분석·관제 / Rocky 9.7	Apache 2.4.62 · PHP 8.4.23 · Python 3.9.25	psms.mg.com / ALPACA · 원격 로그 TCP 514 수신
MS03 / MS04	네트워크 원격 관리 / Rocky 9.7	Python 3.9.25	R12·R13 경로 연결 · 관리 접근·설정
IDS02 / IPS02	모니터링망 관찰·통제 / Rocky·FreeBSD	Snort 3.12.2 · pfSense 2.8.1 · Suricata 7.0.11	SNMP·DNS·SSH·DHCP · 허용 관리 통신 중심

본 포트폴리오는 팀 프로젝트 "쇼핑몰 인프라 구축 및 모의 해킹과 보안 솔루션 점검"(메가스터디 AI 캠퍼스 정보보안 전문가 과정, 2026.08) 결과보고서에서 작성자(최지우)의 모의해킹 수행 범위를 중심으로 발췌·재구성한 것이다.

C-1. 네트워크

본 기술 리스트는 프로젝트 전체에서 영역·세부 유형으로 정리한 카탈로그다. 상세 수행 내용은 4·5장을 참조한다.

세부 유형	기술 · 서비스
운영체제·장비	Cisco Router / Switch (GNS3, c7200-c3745 이미지)
라우팅 프로토콜	EIGRP(AS 100-200) · RIPv2 · Static Route · Default Route · Floating Route
라우팅 기법	Redistribute · NAT(정적·동적·PAT) · Manual/Auto Summary · Offset-list · Variance · Split Horizon · Passive Interface · RTO·Stub(SIA 방지) · Distribute-list
스위칭 기법	VLAN · VTP · STP · Port-Security · SPAN(미러링) · Switch DHCP
WAN·링크	Frame Relay(P2P·Multipoint) · PPP(PAP·CHAP)
보안·인증·관리	ACL(접근 제어) · Key-chain(라우팅 인증) · SSH(원격 관리)

C-2. 서버·서비스

서버 구축·운영에 사용한 운영체제, 서비스/패키지, 보안 도구를 세부 유형으로 분류한다.

세부 유형	기술 · 서비스 (주요 버전)
운영체제	Rocky Linux 9.7 · Ubuntu 24.04 · Windows Server 2025 · FreeBSD(pfSense)
웹 서버	Nginx 1.28.0 / 1.24.0 · Apache 2.4.62 · IIS 10.0 · Virtual Hosting
웹 애플리케이션	PHP 8.4.23 / 8.0.30 · PHP-FPM · Python 3.9.25 · Jupyter 2.20.0 · Pydio Cells 5.0.2 · ownCloud 10.16.0
DBMS·DNS·IP	MariaDB 10.5.29 · MySQL Client · Microsoft DNS(Master) · BIND9 9.16.23(Slave) · DHCP IPv4
파일·전송	SMB(Samba) 4.19.5 · FTP(vsftpd) 3.0.5 · Rsync 3.2.7 · SCP
디스크·운영	RAID(5 · 1+0) · Quota · Cron(스케줄러)
모니터링	MRTG 2.17.7 · Cacti 1.2.26 · Monitorix 3.16.0 (SNMP 기반)
보안(호스트·경계)	iptables 1.8.10 · firewalld 1.3.4(Rich Rules) · UFW 0.36.2 · TCP Wrapper · ICMP Ignore · pfSense 2.8.1 · Snort 3.12.2 · Suricata 7.0.11

C-3. 모의해킹 · 관제

모의해킹 공격 기법·도구와 관제 기술을 세부 유형으로 분류한다.

모의해킹

세부 유형	기술 · 도구
운영체제	Kali Linux · Rocky 9.7 · Windows 2025
공격 기법	SQL Injection · Stored/Reflected XSS · File Upload · File Inclusion · Broken Access Control · Reverse Shell · Brute Force · RLO · Scan(정찰)
툴	Nmap · Zenmap · Wireshark · Burp Suite · hydra · scapy
자체 개발(참여)	PCrafter(패킷 크래프팅) · real_main.py(엔드포인트 탐색) · Vulnmart_ATTACK.py(시나리오 자동화)

관제

세부 유형	기술 · 도구
침입 탐지·차단	Snort 3.12.2 · Suricata 7.0.11 · pfSense 2.8.1
패킷·로그 수집	libpcap · tcpdump · syslog-ng · rsyslog
Python 라이브러리	PyMySQL · Paramiko · Netmiko · dpkt
데이터·분석	MariaDB 10.5.29 · GeoIP2
자체 통합 프로그램	ALPACA NSM (공격 특징·탐지 룰 제공 측면에서 연계)